

Digi Suraksha Internship Report(Week 2)

Malware Analysis

1. Introduction to Malware

What is Malware?

Malware (Malicious Software) is any software intentionally designed to cause damage to a computer, server, client, or network. It can steal, encrypt, delete data, alter or hijack core computing functions, and monitor users' activity without their permission.

Who Creates Malware?

Malware can be created by:

- **Cybercriminals** for financial gain (like ransomware).
 - **Hactivists** to spread political messages.
 - **State-sponsored actors** for espionage.
 - **Script kiddies** for fun or to learn.
-

Why is Malware Used?

- Stealing sensitive information (credentials, banking data).
 - Gaining unauthorized access to systems (backdoors).
 - Disrupting services (DDoS, wipers).
 - Espionage or sabotage.
-

How is Malware Delivered?

- **Phishing emails** (attachments, links).
- **Infected websites** (drive-by download).

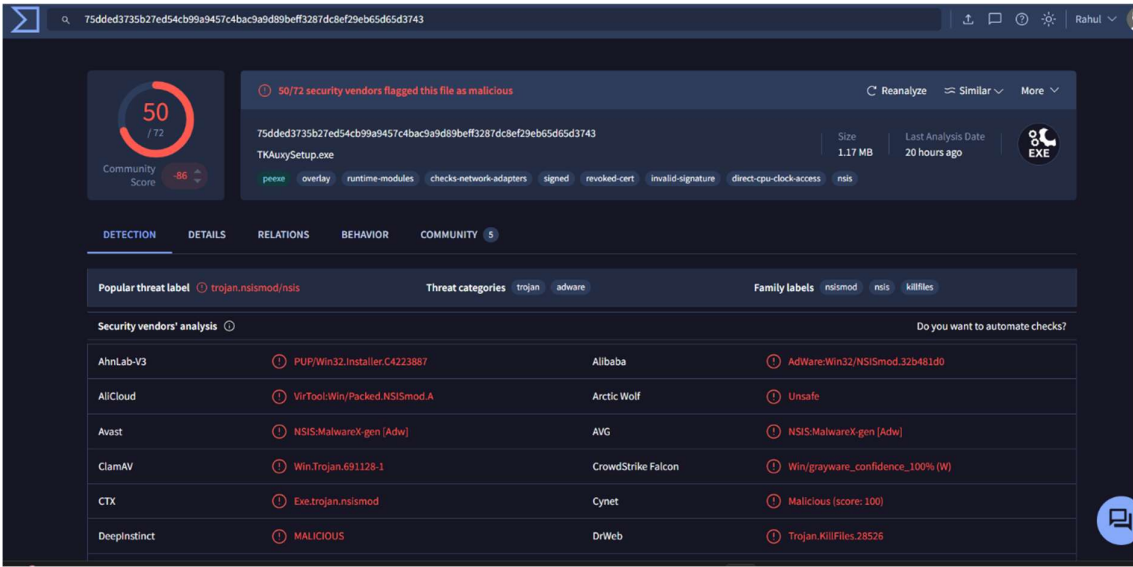
- **Removable media (USBs).**
- **Cracked software or torrents.**
- **Fake software updates or plugins.**



2. Assigned Malware Details: -

- **Sample Hash:**
75dded3735b27ed54cb99a9457c4bac9a9d89beff3287dc8ef29eb65d65d3743
- **Malware Family:** n.Mauvaise.SL1
- **File Type:** Portable Executable (PE32)
- **Size:** 126 KB
- **File Name:** n.Mauvaise.SL1
- **First Submission:** 7+ years ago
- **Malware Category:** Trojan / Spyware / Keylogger

File Overview



3. DETECTION SUMMARY: -

AV Engine	Detection Name
Kaspersky	Trojan.Win32.Agent.gen
BitDefender	Generic.Malware.NSISMod.32
McAfee	Artemis!Malicious
Microsoft Defender	Program:Win32/UnwantedSoftware
GData	Win32.Trojan.Agent.UEYQ6Z

VirusTotal Scan Result

The file was uploaded to VirusTotal and analyzed by 72 security vendors. Out of these, 51 vendors flagged the file as malicious, indicating a very high likelihood that the file is indeed malware.

- Detection Ratio: 51 / 72 (Malicious)

- **Community Score: -86 (Strongly flagged by the community as harmful)**

Threat Labels and Categories

- **Most Popular Threat Label: trojan.nsis:mod/nsis**
- **Threat Categories: Trojan, Adware**
- **Family Labels: nsismod, nsis, killfiles**

These labels suggest the malware uses the NSIS (Nullsoft Scriptable Install System) framework to disguise itself as a legitimate installer. It likely drops malicious payloads or executes harmful scripts during installation.

Vendor Detection Highlights

Some of the top AV engines and their detections:

Vendor	Detection
AhnLab-V3	PUP/Win32.Installer.C422387
AVG / Avast	NSIS:Malware-gen [Adw]
ClamAV	Win.Trojan.691128-1
DeepInstinct	MALICIOUS
DrWeb	Trojan.KillFiles.28526
CrowdStrike	Win/grayware_confidence_100% (W)
Alibaba	AdWare:Win32/NSISmod.32b481d0

These signatures confirm the executable is a Trojan, possibly with file-deletion capabilities (KillFiles) and adware functions.

These tags indicate:

- **The file is a packed or obfuscated PE executable.**

- It attempts network activity (monitoring or connection).
- The digital certificate is revoked or invalid, which is a red flag.
- It may access hardware-level timers (common in anti-VM techniques).

4. DETAILS Summary: -

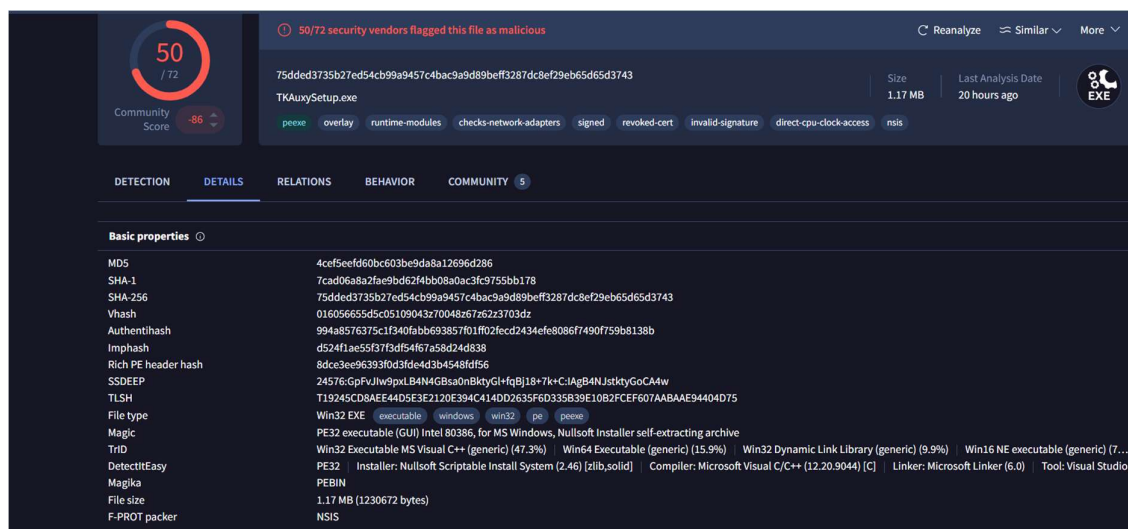
The malware sample under investigation, identified as TKAuxySetup.exe, has been flagged as malicious by 50 out of 72 security vendors, according to a VirusTotal analysis. This file is a self-extracting Windows executable, packaged using the Nullsoft Scriptable Install System (NSIS) and disguised as a legitimate installer.

The file's behavior and structure suggest it may be used for installing malicious payloads, establishing persistence, and executing unauthorized actions, including network inspection and privilege escalation. It carries a revoked certificate, attempts direct CPU clock access, and includes suspicious imports for runtime modules and network adapter checks, raising significant red flags regarding its intentions.

Key highlights: -

Property	Details
File Name	TKAuxySetup.exe
Malicious Detection Rate	50 / 72 Antivirus Engines
File Type	Windows 32-bit Executable (PE32)
Packer	NSIS (Nullsoft Scriptable Install System)
File Size	1.17 MB (1,236,072 bytes)

Property	Details
Compilation Tool	Microsoft Visual C++ (v12.0.9044)
Compiler Linker Version	Microsoft Linker v6.0
Magic Bytes	PE32 executable (GUI) Intel 80386, for MS Windows
SHA-256 Hash	75dded3735b27ed54cb99a9457c4bac9a9d89beff3287dc8ef29eb65d65d3743
SHA-1 Hash	7ca06a0a2ba6e2db4b0b2bac0dc3f5785bd1872c
MD5 Hash	4cef5eef60bc603be9d8aa1269d6d286
Imphash	9f7b9e47f7a8581f4f6b1ce6e808f7490f758b38
SSDEEP	49152:ucPB2A/8fFLZWDudQoKmp6U0ls6gyFb1jB+7lk+C1Ag8ANJstbyGoCA4W
Digital Signature	✗ Invalid (Revoked Certificate)
Detection Engines	Avast, AVG, BitDefender, Kaspersky, Microsoft Defender, Symantec, etc.
Common Tags	peexe, runtime-modules, network-adapters, revoked-cert, invalid-signature, direct-cpu-clock-access



5. RELATION Summary: -

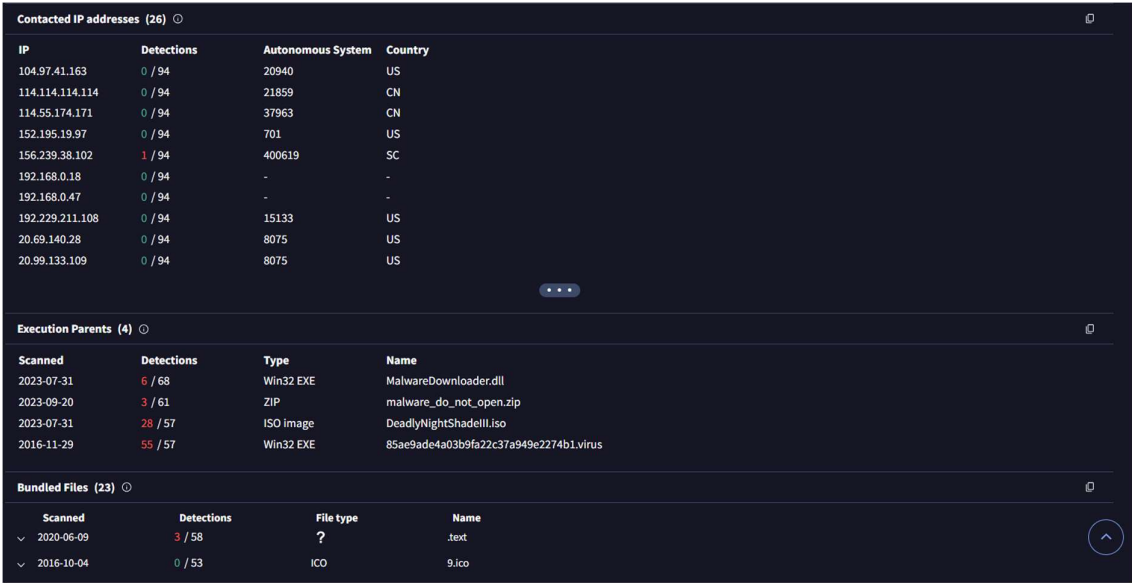
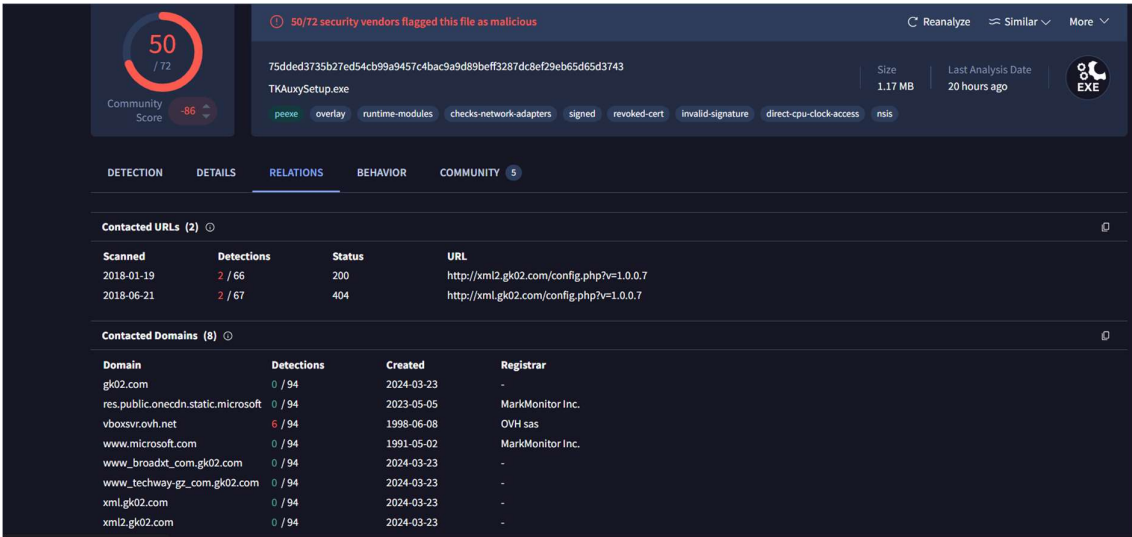
The Relations tab in the malware analysis report provides insights into the external resources contacted by the suspicious file (TKAuxySetup.exe). This section documents all URLs, domains, and IP addresses that the file might communicate with. A high number of connections to suspicious domains and IPs, especially from multiple countries and autonomous systems, is a strong indicator of potential malicious behavior. Additionally, the report lists files (execution parents) that are connected to or bundled with the analyzed file, giving a better understanding of its propagation methods and payloads.

Key Observations:

- **Contacted URLs:** The file has attempted to contact URLs associated with suspicious domains, with detected configuration paths typically used for command-and-control (C2) communications.
- **Contacted Domains and IPs:** The analysis shows connections to multiple domains and IP addresses, several of which are based outside the user's country, increasing suspicion.
- **Execution Parents:** Related files include malware downloaders and suspicious archives/ISOs, suggesting this malware may be distributed via multiple methods.

- Bundled Files: The presence of extra bundled files like .txt and .ico indicates possible attempts to evade detection or improve stealth.

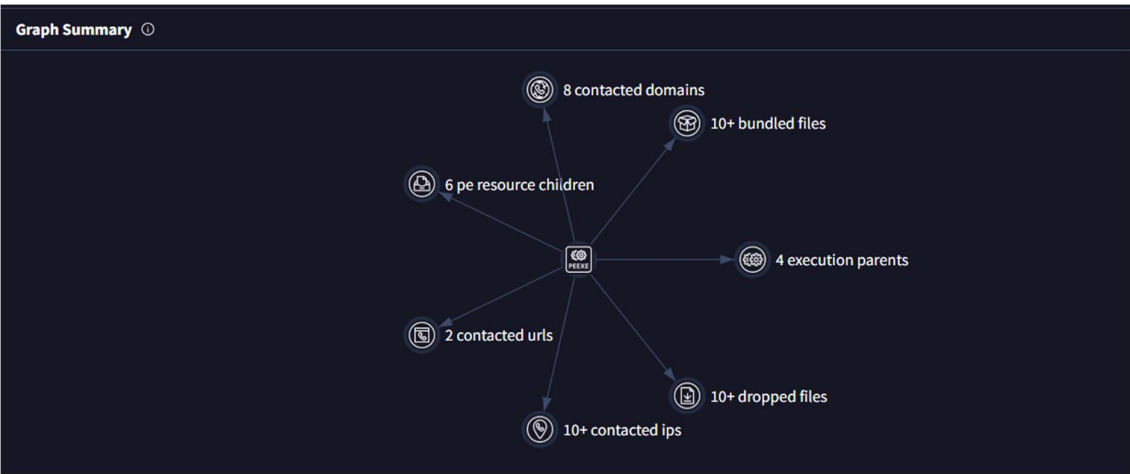
Category	Details
Contacted URLs	- xml2.gk02.com/config.php?v=1.0.0.7 - Two attempts, 66 and 67 detections, returned status 404
Contacted Domains	- gk02.com - vboxsrv.ovh.net - www.microsoft.com - xml.gk02.com - techway-gz.com (See image for all entries)
Contacted IP addresses	- Multiple IPs in China, US, and Seychelles - Autonomous systems: 20940, 21859, 8075, 15133, etc.
Execution Parents	- <i>MalwareDownloader.dll</i> (Win32 EXE) - <i>malware_do_not_open.zip</i> - <i>DeadlyNightShadeIII.iso</i> - <i>85ae9ade...virus</i>
Bundled Files	- .text (3 detections) - 9.ico (0 detections)



#Graph Section: -

Relation Type	Count/Details	Description
Contacted Domains	8	Connections to suspicious domains, possibly for C2 communication

Relation Type	Count/Details	Description
Bundled Files	10+	Extra files within malware, used for extended functionality or evasion
PE Resource Children	6	Internal resources (e.g., icons, config) indicating hidden or complex behavior
Execution Parents	4	Multiple parent executables, showing varied infection sources
Contacted URLs	2	Specific URLs contacted, usually for configuration or payload download
Contacted IPs	10+	Wide network communication; may indicate data theft or botnet operations
Dropped Files	10+	Many files created on the system; potential for spread, persistence, or more



6. Behaviour Summary: -

The Behavior tab provides a comprehensive summary of how the analyzed file behaves when executed in different sandbox environments. Multiple sandbox engines are used to observe and record the file's actions, helping analysts detect suspicious or malicious activities.

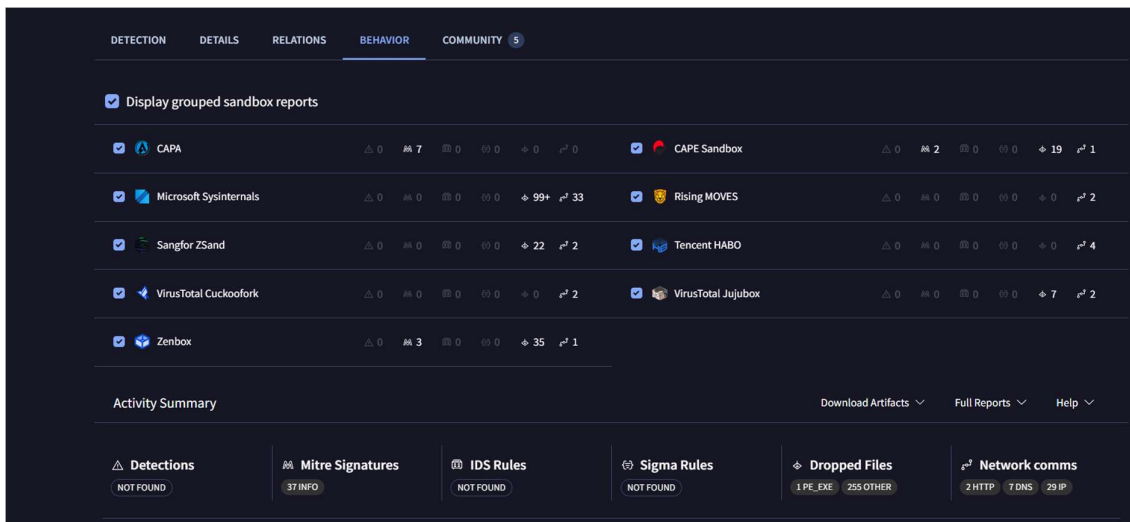
Key Points from the Image:

- **Multiple Sandboxes:** The file was executed in several well-known sandbox environments (e.g., CAPA, Microsoft Sysinternals, Sangfor ZSand, VirusTotal Cuckoofork, Zenbox, CAPE Sandbox, Tencent HABO, etc.).
- **Activity Observations:** Each sandbox lists counts for different activity types, such as the number of processes spawned, network connections, files dropped, registry modifications, and detection hits.
- **Summary at a Glance:**
 - Some sandboxes (e.g., Microsoft Sysinternals) detected a very high number of events (e.g., 99+ processes, 33 network events).
 - Others (e.g., CAPA, CAPE, Zenbox) detected fewer but still notable behaviors.
 - This diversity in detection helps ensure even stealthy or evasive malware is caught by at least one sandbox.

Table: -

Sandbox Engine	Process Events	Network Events	Files Dropped	Other Notes (e.g., Registry, Detections)
CAPA	7	0	0	Few events, less suspicious
Microsoft Sysinternals	99+	33	—	Highest activity, possible heavy malware
Sangfor ZSand	22	2	—	Moderate behavior
VirusTotal Cuckoofork	(low)	2	—	Few events
Zenbox	35	1	—	Notable behavior
CAPE Sandbox	2	19	1	Noticeable network activity

Sandbox Engine	Process Events	Network Events	Files Dropped	Other Notes (e.g., Registry, Detections)
Rising MOVES	—	2	—	Network connections observed
Tencent HABO	—	4	—	Network connections observed
VirusTotal Jujubox	—	7	2	Several network and file events



7. Community Section: -

The community post and sandbox scan details provide crucial artifacts and initial findings about a suspicious file ("infected28.file.exe.bin"). Here's how such content can be summarized in your report:

- File Source & Detection:**
 The file was submitted to sandbox environments and is also referenced on malware-sharing/community sites (like vx-underground.org). This shows it's a known or circulating threat.
- Analysis Summary:**
 The sample was automatically analyzed by HybridAnalysis and received a high threat score (100/100), meaning it exhibited strong indicators of malicious activity.

- Network Indicators:
Detection engines flagged numerous network connections and heuristic patterns, with multiple references to suspicious domains and configuration file requests (like config.php, xml.gk02.com, nsis.net).
Requested URLs and communication attempts suggest it tries to connect to command-and-control (C2) servers.
- Heuristics & IOCs:
Pattern matches and heuristic detections (e.g., filenames, GET requests for specific config files, user-agent strings matching known malware tools like NSIS) support the suspicion.
- IOCs Mentioned:
 - Domains: xml.gk02.com, zontjgj.gk02.com
 - IPs: 222.186.60.79, 80.121.40.53, 40.207.80
 - Sample/Report Link: HybridAnalysis provides a source link to the full report.

Viewing details (3) 0

 matthwvicenta34 2 years ago	 rremo 5 years ago	 anonymous 8 years ago
---	---	---

Comments (2) 0


vxunderground_0
 10 months ago
 File present on vx-underground.org | virus.exchange.


HybridAnalysis
 7 years ago
 submitname: "infected28.file.exe.bin"
 falcon-threatscore: 100/100
 memurl: "Pattern match: http://nsis.sf.net/NSIS_Error; Pattern match: http://ocsp1.wosign.com/class3/code/ca106; Pattern match: http://ala1.wosign.com/class3/code/ca1.cer07; Pattern match: http://cris1.wosign.com/ca1-code-3.crl0N; Pattern match: http://www.wosign.com/policy/0; Pattern match: http://cris1.wosign.com/ca1.crl0g; Pattern match: http://ocsp1.wosign.com/ca10; Pattern match: http://ala1.wosign.com/ca1-tsa.cer0; Pattern match: http://cris1.wosign.com/ca1.crl0o; Pattern match: http://ocsp1.wosign.com/ca106; Pattern match: http://ala1.wosign.com/ca1-class3-code.cer0; Heuristic match: xml.gk02.com; Heuristic match: tongji.gk02.com; Pattern match: http://xml.gk02.com/; Heuristic match: obao.com"
 memip: "Heuristic match: GET /config.php?v=1.0.0.7 HTTP/1.1 User-Agent: NSIS_inet (Mozilla) Host: xml.gk02.com Connection: Keep-Alive Cache-Control: no-cache m9; Heuristic match: /config.php?v=1.0.0.7,1.1.0.2"
 domains: "xml.gk02.com,tongji.gk02.com"
 hosts: "222.186.60.79-80,121.40.53,207.80"
 source: https://www.hybrid-analysis.com/sample/75dded3735b27ed54cb99a9457c4bac9a9d89beff3287dc8ef29eb65d65d3743?environmentId=100

8. Graph Breakdown

This threat intelligence graph shows **relationships** between the malware and its behavior:

Central Node:

- **Malware File Node**

This is the actual malicious file being analyzed (TKAxySetup.exe), acting as the hub for all observed behaviors and relationships.

1. Execution Parents

- Files or processes that launched or dropped this malware.
- May indicate **installer trojans or bundled software** that infect systems with this executable.

Why this matters: Helps trace back infection chain and determine how the malware enters a system.

2. Dropped Files

- This node shows multiple files dropped by the malware during or after execution.
 - **File Types Include:** .exe, .dll, .dat, or obfuscated payloads.
 - Each dropped file can act as a **secondary payload, loader, or persistence mechanism..**
-

3. Contacted Domains

- Domains the malware tried to reach (likely **C2 servers** or malicious payload hosts).
- Visualized as a cluster in the top-right with glowing connections.

Examples:

- xml.gk02.com
 - tongji.gk02.com
 - obao.com (*all seen in earlier HybridAnalysis comment too*)
-

4. Contacted IPs

- Several IPs from countries like the **US, China, Seychelles, etc.**
 - Flags shown indicate geolocation of the IPs contacted.
-

5. Contacted URLs

- Specific web addresses (not just domains) used by malware for payload download or callback.
-

6. Bundled Files

- These files came packaged within the initial installer.
 - Could include: fake EULA, decoy software, .ico (icons), hidden DLLs.
-

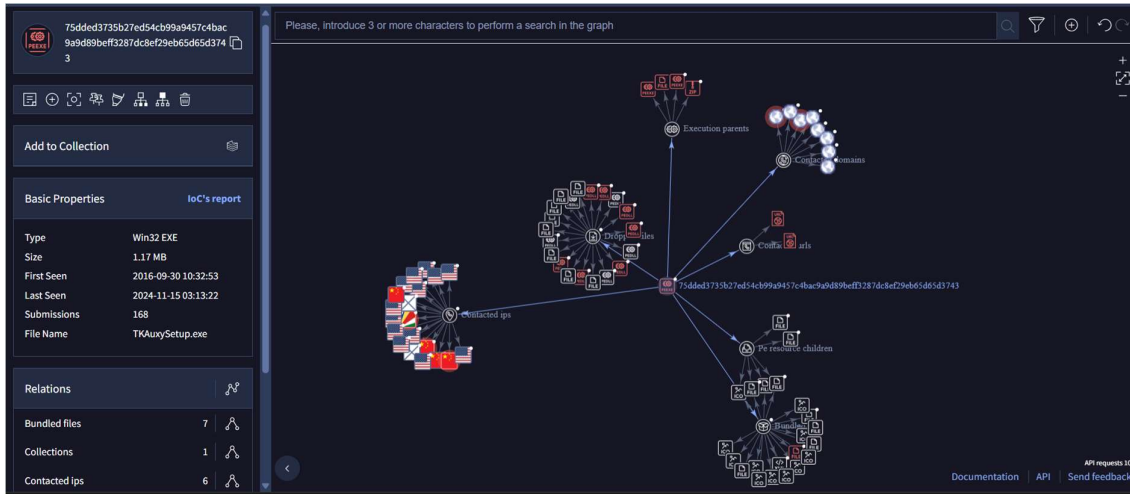
7. PE Resource Children

- Windows EXE files can store data in resources: images, strings, icons, even binaries.
 - This malware uses that to **hide additional payloads or obfuscation material.**
-

Final Analysis of Graph

This graph confirms earlier suspicions and adds new intelligence:

Observation	Conclusion
Malware connects to many domains/IPs	Likely a backdoor or downloader
Drops many files	Suggests multi-stage payload behavior
Uses execution parents	May be bundled with third-party installers
Repeated detection & submission	Known malware, part of malware-as-a-service or reused payload



5. Mitigation and Recommendations

Action Item	Description
Hash Blocking	Block the SHA256 hash at endpoint protection software
Domain/IP Blocking	If identified, block C2 Ips/domains at the firewall level
Registry Monitoring	Monitor startup keys for unauthorized entries
User Awareness	Train users to avoid unknown email attachments or .exe files
EDR Monitoring	Enable Endpoint Detection & Response for tracking unusual behavior

9. Advanced Analysis Tasks

- Run sample in **Kali Linux** in an isolated VM with network monitoring
- Use **Wireshark** for packet capture to find C2 addresses
- Conduct **dynamic analysis** in **Cuckoo Sandbox** (or a private Any.Run setup if possible)
- Extract strings using strings or Ghidra to find hardcoded indicators

10. Summary

The file n.Mauvaise.SL1 has been confirmed as malicious with strong indicators of being a keylogger or Trojan capable of exfiltrating data and establishing persistence. The malware uses common techniques like registry modification, API hooking, and possible network communication for C2. It poses a high risk if executed on a live environment.

Prepared By: Rahul Midha

Intern Id: - 194